

Veslo

Security & Data Processing Brief

Condensed two-page reference for client IT and information-security review

Local-first runtime — ready for on-premise deployment

The agentic runtime executes on the user's own device. Customer files and workspaces stay on-device by default. AI inference is currently delegated to a managed external provider configured for Zero Data Retention.

1. Executive summary

In brief. Veslo is a local-first, cloud-backed control surface for agentic work. The desktop application runs the workflow on the user's device, while cloud services provide identity, synchronization and centrally governed AI access.

- **Local-first execution.** Workspace files, source code and tool execution stay on-device by default.
- **On-premise ready.** The runtime is local by architecture and can operate inside the client's network.
- **Zero Data Retention.** Prompts and completions are processed transiently by the configured AI provider and are not retained or used for training.
- **Centralized AI access.** End users do not hold provider API keys; administrators bind users to approved providers and models.
- **Two-layer authorization.** Workspaces are explicitly authorized, and sensitive actions require per-run user permission.
- **End-to-end audit trail.** Each run records prompts, plans, tool calls, permission decisions, outputs and artifacts.

2. Data handling summary

Data category / current protection	
Workspace files, source code, attachments	User device only by default; not transmitted unless explicitly moved or pasted into a prompt.
Prompt and completion content	Veslo AI gateway to configured ZDR provider over TLS 1.3; transient processing only.
Identity, run metadata and audit records	Veslo Cloud or customer-hosted control plane; encrypted in transit and at rest.
End-user secrets	OS keychain on the user's device; never written to repository or cloud.

3. Security at a glance

Control / position	
Local engine	Loopback only; no inbound firewall rule required; origin and CSRF checks protect against local cross-origin and DNS-rebinding.
Transport	TLS 1.3 on all cloud-bound paths; optional remote execution also uses scoped credentials over TLS 1.3.
Credential model	Provider API keys stay in a server-side credential pool and can be rotated centrally without end-user action.
Desktop integrity	Signed binaries, Apple notarization on macOS, Authenticode on Windows and signature-verified auto-update.
Authentication	Browser-delegated OIDC against the customer's IdP; MFA and step-up controls remain with the IdP.
Audit	Per-run exportable records plus structured security events suitable for SIEM ingestion.

4. Compliance posture

- **DPA package.** Sub-processor list, EU SCCs and a Transfer Impact Assessment template are provided where international transfers apply.
- **Provider assurance.** The configured AI provider operates under ZDR and holds SOC 2 Type 2; report references are included in the DPA package.
- **Veslo assurance.** SOC 2 Type 2 and ISO 27001 for Veslo Cloud and the Veslo AI gateway are on the assurance roadmap; internal controls are available under NDA today.
- **Data residency.** Cloud-synced metadata is stored in the customer's deployment region; on-premise deployments keep residency inside the customer network.

Roadmap: stricter locality

Native local inference, own inference servers on customer-controlled GPU hardware and self-service customer-hosted control plane deployment are in active development. Combined, these remove external AI dependency and keep prompt traffic inside the customer network end-to-end.

5. Review answers

- **Are workspace files uploaded by default?** No. They stay on-device unless explicitly moved, pasted into a prompt or routed to an enabled remote runtime.
- **Are prompts stored by Veslo?** Yes, in the run audit record. Retention is configurable and governed by the DPA; on-premise deployments keep records in the customer environment.
- **Does the AI provider train on customer prompts?** No. ZDR excludes prompt and completion content from training, fine-tuning and evaluation.
- **Where do vulnerability reports go?** To the published security contact and security.txt address with PGP; high-severity reports are acknowledged within one business day.